[Organization's Name] Controls and Compliance Audit

Prepared For:
Date: *DD / MM / YYYY*
Prepared By:

Executive Summary:

Purpose: to systematically evaluate our organization's security controls, policies, and infrastructure to identify vulnerabilities before attackers can exploit them**.**

Top Risks:

[List the top 3-5 risks identified, ordered by severity. E.g. 1. No encryption on customer PII (High) 2. No disaster recovery plan (High) 3. Legacy systems without access controls (Medium)]
[Overall risk rating: High / Medium / Low - justify in one sentence.]

Business Impact: ***[High / Medium / Low]***

Audit Scope & Objectives:

Scope: This audit covers [Organization's name]' digital infrastructure, physical store assets, and adherence to PCI DSS and GDPR and Egypt's Personal Data Protection Law (Law No. 151 of 2020) regulatory frameworks.

Objectives: Assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices that need to be implemented to improve [Organization's name]' security posture and provide actionable recommendations for risk mitigation.

Audit Methodology:

This audit followed a comprehensive, multi-phase approach to evaluate [Organization's name]' security posture and compliance readiness:

1. **Documentation Review:** Review of existing security policies, asset inventories, and compliance frameworks.
2. **Stakeholder Interviews:** Discussions with key personnel to understand operational workflows, access control practices, and existing risk management strategies.
3. **Physical and Logical Assessment:** Evaluation of physical security measures (locks, CCTV) and logical security configurations (firewall rules, legacy system access).
4. **Gap Analysis:** Comparing existing controls against industry best practices (PCI DSS, GDPR, SOC 2) to identify vulnerabilities.

Controls assessment checklist

Severity Rating Scale:

High - Immediate risk to data confidentiality, integrity, or availability. Remediation required within 30 days.
Medium - Significant gap increasing risk exposure. Remediation recommended within 90 days.
Low - Minor weakness or best-practice deviation. Remediation recommended within 180 days.

Yes	No	Control	Severity / Priority	*Explanation*
☐	☐	Least Privilege		
☐	☐	Disaster recovery plans		
☐	☐	Password policies		
☐	☐	Separation of duties		

☐ ☐ Firewall

☐ ☐ Intrusion detection system (IDS)

☐ ☐ Backups

☐ ☐ Antivirus software

☐ ☐ Manual monitoring, maintenance, and intervention for legacy systems

☐ ☐ Encryption

☐ ☐ Password management system

☐ ☐ Locks (offices, storefront, warehouse)

☐ ☐ Closed-circuit television (CCTV) surveillance

☐ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	Severity / Priority	*Explanation*
☐	☐	Only authorized users have access to customers' credit card information.		
☐	☐	Credit card information is accepted, processed, transmitted, and stored internally, in a secure environment.		
☐	☐	Implement data encryption procedures to better secure credit card transaction touchpoints and data.		
☐	☐	Adopt secure password management policies.		

General Data Protection Regulation (GDPR)

Yes	No	Best practice	Severity / Priority	*Explanation*
☐	☐	E.U. customers' data is kept private/secured.		
☐	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.		
☐	☐	Ensure data is properly classified and inventoried.		
☐	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.		

Egypt Personal Data Protection Law (Law No. 151 of 2020)

Yes	No	Best practice	Severity / Priority	*Explanation*
☐	☐	Personal data is collected and processed only with the data subject's clear, informed consent, unless the law allows otherwise; consent can be withdrawn. (Exec. Regs. Arts. 2–3)		
☐	☐	A retention period is defined for each purpose of collection, and data is erased once that purpose is fulfilled unless a legal obligation requires keeping it. (Exec. Regs. Arts. 2–3)		
☐	☐	Data subjects have a mechanism to access, correct, and object to the processing of their personal data. (Exec. Regs. Arts. 2–3)		
☐	☐	Sensitive personal data (e.g., health, biometric, religious beliefs) is processed only with explicit written consent and stricter security controls. (Exec. Regs. Art. 14)		
☐	☐	Written consent from the legal guardian is obtained before collecting or processing the data of children under 15. (Exec. Regs. Art. 15)		
☐	☐	There is a plan to notify the Personal Data Protection Center (PDPC) within 72		

		hours of a breach, and affected data subjects within three working days. (Exec. Regs. Art. 5)
☐	☐	A Data Protection Officer (DPO) is appointed and registered with the PDPC. (Exec. Regs. Arts. 7–12)
☐	☐	The required PDPC license or permit for controller/processor activities has been obtained. (Exec. Regs. Art. 19)
☐	☐	A PDPC license or permit is obtained before any personal data is transferred outside Egypt. (Exec. Regs. Art. 16)
☐	☐	Separate PDPC licenses are held for direct electronic marketing and for visual surveillance (CCTV) in public places. (Exec. Regs. Arts. 28, 31)
☐	☐	Processors handle personal data only under the controller’s written instructions, never beyond the stated purpose, and delete or return it when processing ends.
☐	☐	Personal data records and processing activities are documented, inventoried, and kept up to date.
☐	☐	Technical and organizational safeguards (e.g., encryption, access controls, logging) protect

		personal data from unauthorized access, loss, or disclosure.		
☐	☐	If the organization is based outside Egypt, an authorized local representative is appointed in Egypt (if applicable). (Exec. Regs. Art. 3)		

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	**No**	**Best practice**	**Severity / Priority**	***Explanation***
☐	☐	User access policies are established .		
☐	☐	Sensitive data (PII/SPII) is confidential/private.		
☐	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.		
☐	☐	Data is available to individuals authorized to access it.		

Recommendations:

[List prioritized recommendations by severity. Each entry: (1) Name the control/compliance gap. (2) State the corrective action. (3) Assign a stakeholder owner. (4) Set a target remediation timeframe.]
[HIGH example: Implement AES-256 encryption on all customer PII databases. Owner: IT Security. Target: 30 days.]
[MEDIUM example: Develop and test a formal Disaster Recovery Plan. Owner: IT + Executive Management. Target: 90 days.]
[LOW example: Deploy a centralized password management system. Owner: IT Administration. Target: 180 days.]

Stakeholder Roles & Responsibilities

To successfully implement the recommended controls and ensure ongoing compliance, responsibilities are allocated across the following key stakeholder roles:

- **Executive Management (CEO & Leadership):**

[Approve and fund recommended controls. Champion a security-first culture. Review audit findings and sign off on remediation timelines. Ensure all compliance obligations are met at the organizational level.]

- **IT Department (IT Security & Administration):**

[Lead technical implementation: firewall, encryption, IDS/IPS, and access management. Maintain system logs, conduct regular vulnerability assessments, and own disaster recovery planning and testing.]

- **Facilities / Operations Team:**

[Manage physical security: locks, CCTV, and access badges. Maintain and test fire detection/suppression systems. Coordinate with IT on physical access to server rooms and critical hardware.]

- **Human Resources (HR):**

[Enforce security awareness training for new hires and annually thereafter. Manage onboarding/offboarding access provisioning. Maintain records of signed acceptable use and data handling policies.]

- **All Employees:**

[Adhere to all security policies including password and data handling procedures. Report suspicious activity or phishing attempts to IT immediately. Complete mandatory security training within assigned timeframes.]